

FpAuthAnalysis

Fingerprint Authentication Misuse Analyzer

A Static Analysis Framework Inspired by NDSS Research

Ajay Vanama – 2023UCP1625
Jagat Singh – 2023UCP1616

Department of Computer Science and Engineering
Malaviya National Institute of Technology Jaipur

Computer and Network Security — 22CST352

Outline

- ① Motivation & Background
- ② Related Work
- ③ System Architecture
- ④ Dataset & Experimental Setup
- ⑤ Implementation
- ⑥ Results & Analysis
- ⑦ Novelty Work
- ⑧ Conclusion

- Biometric authentication is widely used in Android applications.
- Android provides APIs such as:
 - FingerprintManager
 - BiometricPrompt
 - CryptoObject
- Incorrect implementation can lead to:
 - Authentication bypass
 - Unauthorized access
 - Weak biometric security

Problem Statement

Many Android applications misuse fingerprint APIs due to:

- Missing cryptographic validation
- Improper lifecycle handling
- Weak callback verification
- Authentication without `CryptoObject` binding

These vulnerabilities compromise application security.

Project Objectives

- ① Analyze Android APKs using static analysis
- ② Detect biometric permissions
- ③ Identify fingerprint API usage
- ④ Detect lifecycle vulnerabilities
- ⑤ Analyze authentication callbacks
- ⑥ Verify CryptoObject usage
- ⑦ Generate structured reports

Inspired by NDSS Research Paper:

“An Empirical Study on Fingerprint API Misuse with Lifecycle Analysis in Real-world Android Apps”

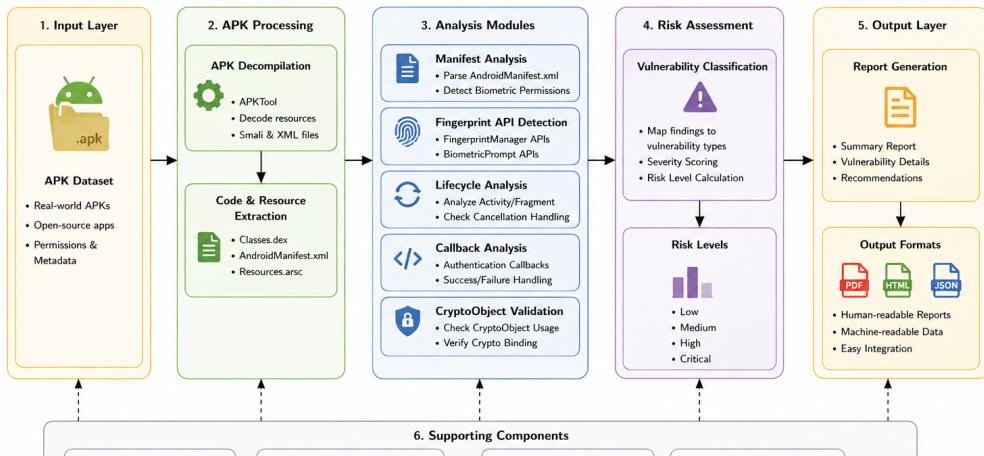
Existing Tools:

- FlowDroid
- Androguard
- JADX
- APKTool

System Architecture

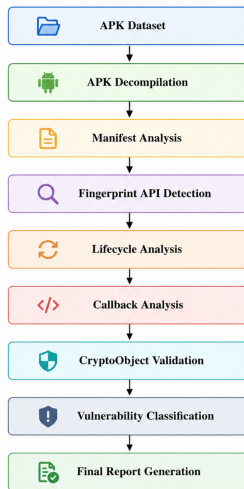
3.1 Architecture Overview

The following figure illustrates the high-level architecture of FpAuthAnalysis and the flow of data through each component.



Workflow Pipeline

3.2 Workflow Pipeline



Technology Stack

- Python 3.12
- Java 11
- APKTool
- FlowDroid
- Androguard
- Android SDK
- Ubuntu WSL

APK Decompilation

- APKTool used to decode APKs

Permission Analysis

- Detects:
 - `USE_FINGERPRINT`
 - `USE_BIOMETRIC`

Fingerprint API Detection

- `FingerprintManager.authenticate()`
- `BiometricPrompt.authenticate()`

Dataset Applications

- Dashlane
- Bitwarden
- KeePassDX
- Aegis
- Standard Notes
- AppLock

Environment

- Ubuntu 24.04
- Java 11
- Python 3.12

Detected Successfully

- Fingerprint permissions
- Biometric API usage
- Lifecycle handling patterns
- Authentication callbacks

Limitations

- Static analysis cannot observe runtime behavior
- Obfuscation affects accuracy
- APK bundles are difficult to analyze

- Lightweight replication using curated APK dataset
- Modular detection pipeline:
 - detect_misuse1.py
 - detect_misuse2.py
 - detect_misuse3.py
 - detect_misuse4.py
- Static-only analysis without:
 - Root access
 - Frida instrumentation
 - Emulator dependency
- Educational reproducible workflow using Ubuntu WSL

Conclusion

- FpAuthAnalysis successfully detects fingerprint authentication misuse.
- Provides automated APK analysis and vulnerability classification.
- Demonstrates practical Android security research workflow.

Future Work

- Dynamic runtime analysis
- Frida-based instrumentation
- Machine learning classification

- ① NDSS Fingerprint API Misuse Paper
- ② Android Developer Documentation
- ③ FlowDroid Documentation
- ④ APKTool Documentation
- ⑤ Androguard Documentation

Thank You!

Ajay Vanama - 2023UCP1625
Jagat Singh - 2023UCP1625

Department of Computer Science and Engineering
Malaviya National Institute of Technology Jaipur